ENGINEERING AUDIT · CONFIDENTIAL

BitForBytes Full-Site Audit

A complete engineering review of the VLSI learning platform — architecture, performance, security, accessibility, code quality, and SEO/UX — with every strength and every defect, ranked.

Scope	frontend/ (~95,630 LOC · 1,023 TS/TSX files) · backend/ (Express) · supabase/ (4 migrations + edge fn)
Method	6 parallel read-only audits · file-level evidence · tsc verified (exit 0)
Date	14 Jul 2026
Stack	React 18 · Vite 5 · TypeScript · Tailwind · Supabase

SECTION 00

Executive Summary

BitForBytes is a **genuinely well-engineered SPA** with several best-in-class systems — the theme store, the SEO/prerender pipeline, the code-splitting strategy, the resilient chunk-loader, and the Supabase RLS model are all things most production apps get wrong and this one gets right. The platform is **production-capable today**.

The weaknesses are almost entirely **debt, not breakage**: ~20% of the frontend is dead code, ~1.3 GB of lecture video ships from the app origin, lint/hooks enforcement is effectively off, and there's a scattering of accessibility and hardening gaps. None of these stop the site working; all of them raise the cost of the next 10 features and the next Lighthouse score.

HEALTH SCORECARD

DIMENSION	GRADE	VERDICT
Architecture	C+	Excellent modern patterns (shared kits, lazy routing) undercut by ~20% dead code and a systemic route↔folder naming drift.
Performance	C	The build config is A-grade; the *assets* are the problem — 1.3 GB origin video + framer-motion on first paint drag real-world load.
Security & Data	B	Strong: RLS everywhere, no leaked secrets, guarded edge function. Latent backend IDOR + missing CSP are the gaps.
Accessibility	B–	Great bones (theme, focus-visible, reduced-motion, drawer) with real gaps in form labels, contrast, and canvas motion.
Code Quality	B–	strict TS + tested Verilog engines + resilient error handling; but lint doesn't gate and hooks rules aren't enforced.
SEO / Content / UX	A–	Best area. Per-route meta, JSON-LD, canonicals, single-sourced gating, 100% completion-screen coverage.

⚑ The one thing to fix first

Set `VITE_MEDIA_BASE_URL` to a real video CDN. **1.3 GB of MP4** (44 files, up to 58 MB each) currently ship from the app origin — the `mediaUrl()` hook already exists, it's just unset. This is the biggest single lever on load time, bandwidth cost, and deploy size, and it's a config change, not a refactor.

ISSUE COUNT BY SEVERITY

CRITICAL 1 HIGH 6 MEDIUM 19 LOW 16 — plus ~40 verified strengths across the six areas.

SECTION 01

Prioritized Action Plan

If you do nothing else, do these — ordered by (impact ÷ effort).

P0 — DO THIS SPRINT

ACTION	AREA	PAYOFF
Move the 1.3 GB of videos to a CDN via `VITE_MEDIA_BASE_URL`; transcode to HLS/WebM	Perf	Huge: load time, bandwidth, deploy size
Add `eslint-plugin-react-hooks` + enable rules-of-hooks & exhaustive-deps (28 current disables are no-ops)	Quality	Catches stale-closure bugs in a hook-heavy app

Add a Content-Security-Policy header (+ drop `allow-same-origin` on the CircuitVerse iframe)	Security	Contains XSS; protects the localStorage auth token
Fix the backend guest-token IDOR (`requireAuth.ts` trusts client-declared `guest_<id>`)	Security	Closes impersonation before any per-user route ships

P1 — NEXT SPRINT

ACTION	AREA	PAYOFF
Delete ~19,800 LOC of dead code (orphan `module1_v2/v3, module2_v3/v4` , the ModulePage subtree, ~10 orphan pages)	Arch	−20% frontend; faster builds & onboarding
Exclude `vendor-animation` (framer-motion) from first-paint preload; adopt `LazyMotion`	Perf	Lighter first paint on every route
Gate infinite/canvas animations on visibility & reduced-motion; cancel rAF on unmount (5 leaks)	Perf / A11y	Battery, jank, vestibular safety
Add `aria-label` / `<label>` to the 94 unlabeled inputs; mark decorative SVGs `aria-hidden`	A11y	Screen-reader usability
Add `onError` fallback to CustomVideoPlayer; add a timeout to `yosysClient.synthesize()`	Quality	No more silent stuck spinners
Mark gated DSD/BE + all RequireAuth routes `noindex` ; unify the Instagram handle	SEO	Removes contradictory crawl signals

P2 — STEADY-STATE CLEANUP

ACTION	AREA	PAYOFF
Collapse the 74 duplicate `/dsd/N` + `/dsd/N/:chapter` routes to one param route per track	Arch	Half the routing table; no desync
Migrate the ~18 gen-1 engines onto the shared `SubModuleShell`	Arch	One shell to fix, not 18
Replace prop-level `any` (129 `: any` + 74 `as any`) with real interfaces	Quality	Restores strict-mode value
Convert noir PNGs (66 MB) to WebP/AVIF; self-host or preconnect Google Fonts; drop 2 unused deps	Perf	Faster LCP; smaller install
Raise low-contrast captions (`white/30-40` , opacity-20/30) to meet WCAG AA	A11y	Legibility for all users

Architecture & Structure

WHAT'S GENUINELY GOOD

✓ **Uniform route-level code-splitting** — every route uses one `named()` + `loadChunk()` lazy helper behind a single Suspense + error boundary.

✓ **Best-in-class theme state** — `useColorScheme.ts` is a single `useSyncExternalStore` singleton: cross-tab sync, OS-pref follow, FOUC-free. The cleanest module in the repo.

✓ **Second-gen module kit** — 16 modules (DSD 14–27, BE 6–10) delegate to shared `SubModuleShell`; their Root files are ~25 lines of pure config. Exactly right.

✓ **Clean access-tier composition** — `RequireAuth` + `ModuleGate` + `PortalLayout` compose as declarative layout routes; the free-vs-gated split is readable.

ISSUES

HIGH **~20% of the frontend is unreachable dead code (~19,800 LOC)**

Three dead zones: orphan version folders `module1_v2/v3, module2_v3/v4` (~9,777 LOC); the unrouted `ModulePage → ModuleContent → SubModule1_x` subtree (~6,694 LOC); ~10 orphan pages (~3,306 LOC).

Impact: inflates search/onboarding cost, tsc/lint time, and hides which code is live. **Fix:** delete after a final grep-confirm (all verified at 0 refs).

HIGH **Systemic route ↔ page ↔ engine number mismatch**

`/module/2` → `pages/ModuleTwo` → `module3_v4/Module3Engine` (self-labelled "Module 03"); `/module/3` → `ModuleThree` *also* self-labels "Module 03". The URL, page name, and folder number disagree at three layers.

Impact: the recently-fixed `/module/2` completion-screen bug was a direct symptom. **Fix:** rename folders to match live routes (or add a mapping doc) and drop the `ModuleTwo/Three/Four` shims.

MEDIUM **Every DSD/BE route declared twice (74 duplicate lines)**

`/dsd/N` and `/dsd/N/:chapter` are separate routes to the same component. **Fix:** one optional-param route per track (`/dsd/:module/:chapter?`).

MEDIUM **Copy-pasted Sidebar/shell across ~18 gen-1 engines**

`ModuleThree` / `ModuleFour` + `dsd_module1-13` + `be_module1-5` each re-implement the same sidebar/header/footer. The `SubModuleShell` refactor was never back-applied. A shell fix must be repeated 18×.

MEDIUM **`binaryStore.ts` is a 687-line god-store**

Zustand stores are wildly uneven (binary 687, gamification 308, simulator 59, ui 17). **Fix:** split by concern.

MEDIUM **Multiple coexisting circuit-simulator stacks**

`simulator/`, `circuit-lab/`, `CircuitCanvas`, CircuitVerse iframe, and `mure/` are parallel implementations with duplicated snapping/wiring logic. **Fix:** designate one canonical, mark the rest legacy.

LOW **`components/level1/` is a misnomer; blanket `_v1` suffix**

Holds all tracks (37 `_v1` folders despite no `_v2`). Rename to `components/modules/`.

LOW **Auth is a non-reactive function call**

`RequireAuth` reads `isAuthenticated()` not a subscribed store; UI won't re-render on session change without navigation.

Metrics · ~114 route entries (74 are base+chapter dupes) · ~42 live module engines · 47 engine folders (9 version-dup slots for ~4 logical modules; 4 fully orphaned) · shared-kit adoption 16/34 modules · 4 Zustand stores (1,071 LOC) · **~19,800 LOC dead (~20%)**.

Performance & Build

WHAT'S GENUINELY GOOD

- ✓ **Aggressive route-level splitting** — ~90 lazy routes behind a resilient `loadChunk` retry helper.
- ✓ **Deliberate `manualChunks`** isolating three/jspdf/monaco/graph/dagre/gsap/anime into route-only `vendor-*` chunks.
- ✓ **`modulePreload.resolveDependencies` filter** drops heavy chunks from eager first-paint preload — three.js (~886 kB) never preloads on the shell.
- ✓ **lucide-react left unchunked on purpose** so Rollup tree-splits icons into route chunks (kills the old ~665 kB eager icon chunk).
- ✓ **Media CDN indirection** funnels every video/poster through one `mediaUrl()`; no prod source maps; yowasp WASM served by static URL only on `/workbench`.

ISSUES

CRITICAL **1.3 GB of lecture video served from origin `/public`**

`public/videos/` = 44 MP4s, 18–58 MB each. The CDN hook only activates if `VITE_MEDIA_BASE_URL` is set at build — **default unset = served from app origin** and copied into `dist`.

Impact: massive origin bandwidth, slow start, huge deploys. **Fix:** point to Cloudflare Stream/Bunny/R2; transcode to HLS.

HIGH **framer-motion is on the first-paint critical path**

Statically imported in **543 files** incl. the landing page and site-wide `MascotWidget`. Its `vendor-animation` chunk is *not* in the `resolveDependencies` exclusion regex, unlike three/pdf/monaco.

Fix: add `vendor-animation` (and `vendor-supabase`) to the filter; adopt `LazyMotion + m`.

HIGH **Unbounded / off-screen animation loops**

136 files use `repeat:Infinity`, 47 run `requestAnimationFrame` loops; only `CircuitBackground` gates on visibility. The rest run off-screen and in background tabs.

Fix: gate with `whileInView` / `useInView` and pause on `document.hidden`.

MEDIUM **rAF loops never cancelled (memory leak)**

`backgrounds/CircuitBoard.tsx` (+4 others) recurse via rAF but cleanup never calls `cancelAnimationFrame` — the loop runs forever after unmount.

MEDIUM **Google Fonts via render-blocking CSS `@import`**

`index.css:3` serializes the request chain; no `preconnect` to gstatic. **Fix:** `<link preconnect>` + `stylesheet` in head, or self-host woff2 with preload.

MEDIUM **Large uncompressed PNGs (~66 MB)**

`public/images/noir/*.png` = 14 files @ 2.5–4.5 MB. **Fix:** WebP/AVIF, resize to display size, route via CDN.

LOW **Two unused heavy deps + monaco from third-party CDN**

`react-force-graph-2d` and `@rive-app/react-canvas` have zero import sites — remove them. Monaco has no `loader.config`, so it fetches from jsdelivr at runtime (breaks offline).

Biggest public assets · `videos/ 1.3 GB · images/ 66 MB · yowasp/ 52 MB (wasm 41) · docs/ 41 MB · circuitverse/ 7.6 MB`
Heavy imports · lazy: three, r3f, jspdf, html2canvas, gsap, anime, dagre, monaco · **eager: framer-motion (543 sites)** · dead: force-graph, rive
Loops · 136 files `repeat:Infinity`, 47 with rAF (5 without cancel).

Security & Backend / Data

WHAT'S GENUINELY GOOD

- ✓ **No private secrets shipped** — repo-wide sweep found only the expected anon key; `HF_API_KEY` is read server-side only (`Deno.env`). `backend/.env` and `.mcp.json` are gitignored.
- ✓ **RLS enabled on every table** — the starter "profiles viewable by everyone" policy is explicitly dropped; email/full_name PII is owner-only.
- ✓ **SECURITY DEFINER RPCs enforce ownership** — `record_module_open` / `record_engagement` require `auth.uid()=owner_key` ; engagement is clamped, monotonic, cross-identity-guarded; aggregate views REVOKE'd from anon.
- ✓ **Edge function `assistant` is well-guarded** — CORS allowlist, per-IP rate limit (25/min), input clamped, key never leaked.
- ✓ **XSS sinks are safe** — all `dangerouslySetInnerHTML` feed static/generated SVG or HTML-escaped markdown; every postMessage handler is a Web Worker channel (no cross-origin window listener).

ISSUES

MEDIUM **Backend trusts unverified `guest_<id>` tokens — latent IDOR**

`backend/src/middleware/requireAuth.ts` accepts any token starting `guest_` and sets `req.user.id = token.slice(6)` (attacker-controlled). Sending `guest_<real-uuid>` impersonates.

Impact today: low (only protected route returns static content; Node backend not on the Hostinger static prod path) — but the flaw is in the repo. **Fix:** HMAC-signed guest tokens; verify against `guest_sessions` .

LOW **Anon clients can spoof/spam analytics rows**

Guest writes are validated by UUID *shape* only, so any anon caller can write under any guest UUID and mint unlimited rows; `guest_sessions` allows unbounded inserts. Data-integrity/spam risk (no PII exposure). **Fix:** edge rate-limit + signed guest key.

LOW **No CSP; CircuitVerse runs same-origin with token in localStorage**

`.htaccess` sets only cache/compression — no CSP/X-Frame-Options. The `supabase_token` lives in localStorage; the CircuitVerse iframe uses `allow-scripts allow-same-origin` (neutralizing the sandbox). Any bundle compromise can read the token. **Fix:** add CSP; drop `allow-same-origin` or serve from a separate origin.

LOW **Backend logs PII on every auth request**

`backend/src/routes/auth.ts` logs email on every signup/signin. **Fix:** redact; log opaque ids at debug level. Also bump `axios ^1.6.7` to latest 1.x (SSRF/redirect fixes).

DATA MODEL

TABLE	RLS	NOTES
`profiles`	✓	Owner-only SELECT/UPDATE; email+name PII correctly locked (starter policy dropped).
`module_history`	✓	Owner-only SELECT (auth); writes via SECURITY DEFINER RPC; guests can't read back.
`module_engagement`	✓	Owner-only SELECT; writes clamped/monotonic/guarded. *Migration 0004 pending apply.*
`guest_sessions`	✓	World-INSERT (no SELECT policy → not readable); self-chosen username (not real PII).
`…_by_module/_by_user views`	✓	REVOKE ALL from anon/authenticated — correct.

Accessibility, Responsive & Theming

WHAT'S GENUINELY GOOD

- ✓ **Reduced-motion handled two ways** — global CSS `@media (prefers-reduced-motion)` + framer-motion wrapped in `<MotionConfig reducedMotion="user">`.
- ✓ **Focus done right** — ring suppressed only for `:focus:not(:focus-visible)`; strong 2px keyboard ring kept.
- ✓ **MobileDrawer is a model impl** — focus trap + restore, `inert` when collapsed, Esc-to-close, scroll-lock, `role="dialog"`, arrow-operable resize handle.
- ✓ **All `<img>` have alt text**; 183 `aria-*` usages; global `overflow-x:clip` mobile safety net; engine arrow-keys guard inputs.
- ✓ **No duplicate local theme copies** — every consumer uses the shared store.

ISSUES

MEDIUM **JS/canvas rAF loops ignore `prefers-reduced-motion`**

`ElectricParticleField`, `CircuitBoard`, `LandingVisuals`, `BinaryRain` run continuous canvas motion with 0 reduced-motion checks (the CSS query only stops CSS animation). Apply the pattern the mascot/showcase already use.

MEDIUM **Form inputs lack programmatic labels at scale**

94 `<input>`, **0** with `aria-label`, only 9 `htmlFor` labels. Placeholder ≠ accessible name. **Fix:** label the text inputs in auth/search/judge.

MEDIUM **400 SVGs, ~4% marked**

Decorative diagrams add screen-reader noise; informative schematics/waveforms have no accessible name. **Fix:** `aria-hidden` decorative, `role="img"+<title>` informative.

MEDIUM **`GatekeeperLanding` gate not keyboard-operable**

Entry surface + "login" are `<div onClick>` with no role/tabIndex/onKeyDown — keyboard/AT users can't enter. **Fix:** use `<button>` / `<Link>`.

MEDIUM **Low-contrast text is systemic**

`text-white/30-40` ×264, `opacity-20/30` on small text ×140; mono captions at 0.4–0.5 fall below WCAG AA 4.5:1. **Fix:** raise to ~0.6–0.7 / use contrast-tuned tokens.

LOW **r3f Canvas scenes: no mobile guard / `dpr` cap**

`LED3DScene`, `Resistor3DScene` (+~10) set no `dpr` / `frameloop="demand"`, 0 mobile guards — full-DPR always-on loop on phones. **Fix:** `dpr={[1,1.5]}`, static image on small viewports.

LOW **No skip-link / `<main>` landmark; a few clickable overlay divs**

Routes wrap in Suspense with no skip-to-content or `<main>`; lab pause screens are `<div onClick>`. Engine key-guard misses `SELECT`/contentEditable.

Metrics · `<img>` without alt: ~0 · clickable non-buttons: 6 (2 real defects) · reduced-motion: ✓ CSS+framer, ✗ canvas rAF · SVG marked ~4% (400 total) · inputs 94 / htmlFor 9 / aria-label 0.

Code Quality, Correctness & Testing

WHAT'S GENUINELY GOOD

✓ `strict:true` and `tsc` gates the build; **zero** `@ts-ignore/@ts-nocheck` in the whole tree.

✓ **The Verilog judge engines ARE tested** — `miniSim`, `seqSim`, `grade`, `schematic` test files cover the core sim/grading logic; `mure/` + `stores/` add 8 more.

✓ **Resilient code-split error handling** — `AppErrorBoundary` distinguishes stale-chunk errors, auto-reloads once (loop-guarded); `loadChunk` retries with backoff.

✓ **Defensive lib/** — `safeStorage()` around all localStorage, fire-and-forget DB writes, idempotent token bridging, worker `onerror` handling.

✓ **i18n graceful fallback** — `pick()/pickList()` fall back to English; a missing Hindi field never breaks a page.

ISSUES

HIGH `react-hooks` **lint rules aren't enforced at all**

`.eslintrc.json` extends only recommended + ts-recommended; `eslint-plugin-react-hooks` isn't installed. Yet **28** `exhaustive-deps` disables exist — **all no-ops** disabling a rule that isn't running.

Impact: neither rules-of-hooks nor exhaustive-deps is checked in a hook-heavy app. **Fix:** install the plugin, enable both rules, then audit the now-active disables.

HIGH **The strict** `lint` **script can't pass — lint gates nothing**

`no-explicit-any` / `no-unused-vars` are `warn` but the script runs `--max-warnings 0`. With 129 `:any` + 74 `as any` + unused vars, `npm run lint` always exits non-zero. Strictness is cosmetic. **Fix:** bump to error + clean, or drop `--max-warnings 0`.

MEDIUM **Pervasive** `any` **erodes the strict guarantee**

129 `:any` (63 files) + 74 `as any` (55 files); component props typed `any` defeat prop-checking (worst: `FSMPlayground`, `CircuitVerseSimulator`). **Fix:** real interfaces; reserve casts for genuine 3rd-party gaps.

MEDIUM **No fallback for video *load* failures**

`CustomVideoPlayer` has no `onError`; a 404'd lecture URL yields a stuck/blank player. **Fix:** `onError` → error state → existing transcript fallback.

MEDIUM `yosysClient.synthesize()` **has no timeout**

Resolves only on a worker message; a wedged 43 MB WASM worker = permanent "Synthesizing" spinner. **Fix:** timeout that rejects and clears pending.

MEDIUM **Placeholder completion handlers are dead logic**

`ModuleContent.tsx` wires 6 sub-modules' `onComplete={(sip)=>console.log(...)}` — completions/SIP rewards computed but never recorded. (Also ~24 stray `console.log` in prod, incl. hot sim loops.)

LOW **Untested pure logic; single app-wide error boundary**

`binaryStore` conversions, `netlistSim`, `synthSchematic` untested. One `AppErrorBoundary` wraps all routes — a render error in one module blanks the whole app.

Metrics · strict ✓ · noUnusedLocals/Params ✗ · `:any` 129 · `as any` 74 · `@ts-ignore` 0 · test files 12 · TODO/FIXME 8 · `console.log` ~24 · exhaustive-deps disables 28 (all no-ops).

SEO, Content & UX Consistency

WHAT'S GENUINELY GOOD

✓ **SEO architecture is genuinely strong** — `seo.ts` hand-tunes title+desc per route; `SeoManager` applies canonical/OG/Twitter/robots + JSON-LD on every nav; static defaults in `index.html` for non-JS scrapers; build-time per-route prerender.

✓ **Valid layered structured data** — Organization + WebSite site-wide, per-route BreadcrumbList, and a `Course` object for module routes.

✓ **Soft-404 handled twice** (fallback `noindex` + runtime); robots disallows all 5 auth pages.

✓ **Gating single-sourced** — `FREE_MODULE_IDS` drives enforcement, visual locks, and sitemap inclusion consistently.

✓ **Completion-screen coverage effectively 100%** — `ModuleComplete` wired into all foundation engines + shared shells (DSD 14–27, BE 6–10). 0 modules missing it.

✓ **Mascot + AI fully wired** (VoltMonkey → AssistantPanel → edge fn, SSE streaming); contact email & `BitForBytes` casing consistent; career data well-sourced (36 refs).

ISSUES

MEDIUM **Instagram handle mismatch (structured data vs real links)**

`index.html` + `seo.ts` `sameAs` → `/bitforbytes`, but all 3 footer links → `/bit_for_bytes`. Org `sameAs` points to a wrong profile (or the links are broken). **Fix:** unify the real handle.

MEDIUM **Auth-gated routes advertise `index,follow`**

Only the 5 auth pages are `noindex`. ~14 `RequireAuth` tool routes + gated DSD/BE modules emit `index,follow` despite redirecting anonymous crawlers to /login. Bounded (excluded from sitemap). **Fix:** mark them `noindex,follow`.

LOW **Foundation modules use bespoke, non-uniform chrome**

`module/1-5` each run separate legacy engines with their own sidebars, and `ModuleThree/Four` still render `// Context`-style faux-code labels. They share ModuleComplete + tokens, so it's cosmetic drift, not breakage.

LOW **Empty "Coming soon" Verilog track in the primary nav**

`HierarchicalGrindTree` shows a `comingSoon:true, modules:[]` card in the track switcher — a visible empty section.

LOW **Icon/social polish**

Only `/logo.png` as icon (no `favicon.ico` / safe-zone maskable → may crop on Android); footer Reddit link is a personal profile; one "BitforBytes" casing typo in a code comment.

Metrics · sitemap URLs: 18 (all public/free; gated correctly excluded) · modules missing completion screen: **0** · user-facing placeholders: 1 intentional stub · gated-route index inconsistency: 1 systemic pattern + 1 social mismatch.

Report compiled from six independent read-only audits over frontend/, backend/, and supabase/. Findings are file-evidenced; the codebase type-checks clean (`tsc --noEmit` exit 0). Severity = (likelihood × blast radius), not effort. · BitForBytes · 14 Jul 2026